

Relatório de Auditoria de Segurança - SecurePlay

04 de setembro de 2026

Revisão auditada: ecae0ef806fb

Escopo: backend, frontend, autenticação, WebSocket, MySQL, Redis, S3, deploy, bundle e histórico Git.

Nota metodológica. As cinco categorias foram mapeadas para NestJS/TypeORM/MySQL (isolamento manual por usuario_id/empresa_id), RBAC por guards, rotas REST por ID, configurações/objetos Git/bundle e sinks React/HTML. Foram reportados somente comportamentos confirmados no código real.

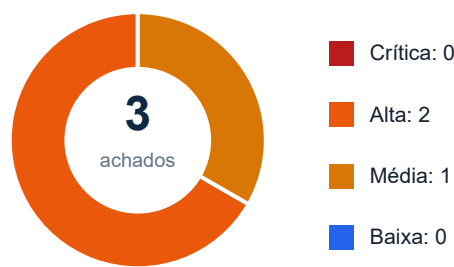
Uso interno - contém evidência de segurança com segredos redigidos

01 Resumo executivo

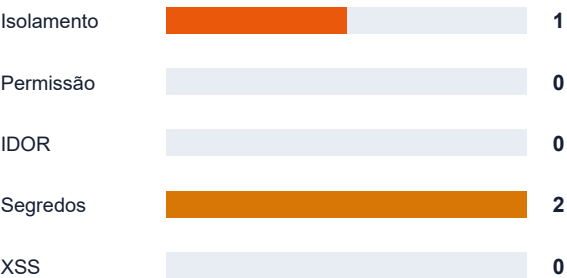
A auditoria confirmou 3 achados acionáveis: 2 de severidade alta e 1 de severidade média. O risco central é a exposição de identidade no ranking entre empresas, seguido por duas falhas no ciclo de vida do segredo JWT. Não foram confirmadas falhas de autorização somente no navegador, IDOR ou XSS.

0	2	1	0	10
Críticas	Altas	Médias	Baixas	Pontos fortes

Achados por severidade



Achados por categoria



02 Stack, escopo e método

Camada	Tecnologia detectada	Como a categoria foi adaptada
Backend	Node.js/TypeScript, NestJS 11, Fastify	Guards globais, controllers e services
Banco	MySQL + TypeORM	Sem RLS; filtros manuais por usuario_id/empresa_id
Auth	Passport JWT, cookie HttpOnly, bcrypt, Redis blacklist	Principal em req.user; RBAC @Roles
Frontend	React 18, Vite 6, Axios, React Router	Gates por role, sinks DOM/HTML e URLs
Tempo real/mídia	Socket.IO e S3/R2 privado	Handshake JWT, rooms e URLs assinadas
Deploy	Docker multi-stage + Render Blueprint	Env vars, defaults, TLS e usuário não-root
Ausente	Sem CI, Helm/Kubernetes ou Terraform	Categorias não foram forçadas nesses artefatos

Cobertura. 17 controllers; 77 handlers HTTP e 79 paths; gateway Socket.IO; 153 arquivos TypeScript no backend; 157 arquivos TS/TSX no frontend; 160 commits e 1.799 blobs Git de até 2 MB examinados. O bundle de produção foi reconstruído e varrido.

Validação. 81 testes backend passaram. Typecheck, verificação de assets e build Vite passaram. O resultado final do build NestJS é registrado no encerramento.

Resultado por categoria

Categoria	Resultado	Evidência de cobertura
1. Banco sem tranca	1 alta	MySQL/TypeORM sem RLS; isolamento manual por usuario_id/empresa_id. Ranking global não aplica empresa_id.
2. Permissão no navegador	0	Gates React de ADMIN/PLATFORM_ADMIN têm @Roles equivalente no backend (34 handlers privilegiados).
3. IDOR	0	Todos os 77 handlers HTTP (79 paths) e as rotas por ID foram cruzados com services/queries.
4. Chaves expostas	1 alta + 1 média	Placeholder JWT aceito e segredo real no histórico; bundle atual sem chave confirmada.
5. Inputs sem tratamento (XSS)	0	Sem sinks HTML/Markdown inseguros/eval de input; sem e-mail HTML no backend.

03 Pontos fortes e pontos fracos

Pontos fortes comprovados

Controle	Evidência
Autenticação padrão	JwtAuthGuard é APP_GUARD; somente 5 handlers públicos (6 paths) usam @Public.
RBAC no servidor	RolesGuard global; 34 handlers privilegiados cobertos por ADMIN ou PLATFORM_ADMIN.
CSRF e CORS	Mutações autenticadas validam Origin e cookie usa HttpOnly/Secure em produção.
WebSocket	JWT é verificado, blacklist Redis consultada e room deriva de payload.sub.
Admin por empresa	Empresa deriva do usuário; convite/usuário usam consulta composta com empresa_id.
IDOR	Notificações, progresso, conquistas, arcade e perfil usam caller/usuario_id.
Conteúdo	GET e progresso validam pré-requisito; CRUD/upload são PLATFORM_ADMIN.
Convites	Token aleatório é armazenado por hash; cadastro trava linha e aplica expiração/uso/e-mail.
Upload	Presigned POST restringe chave, Content-Type e tamanho; perfil valida chave.
XSS	React escapa texto; sem sinks HTML/Markdown, eval de input ou e-mail HTML.

Pontos fracos centrais

Prioridade	Tema	Risco	Achado
P1	Ranking global	Nome civil e foto assinada cruzam tenants por padrão.	SEC-01
P2	Placeholder JWT	Exemplo público satisfaz a checagem de startup.	SEC-02
P3	Histórico Git	Segredo real segue nas branches principais.	SEC-03

04 Tabela consolidada de achados

Severidade	Arquivo/linha	Descrição
Alta	backend/src/dashboard/dashboard.controller.ts:9-17; backend/src/dashboard/dashboard.service.ts:62-93, 103-115; frontend/src/components/sections/HomePage/Ranking/index.tsx:24-26, 193-195	SEC-01 - Ranking global expõe identidade e foto entre empresas. O isolamento do projeto é manual por usuario_id e empresa_id. O endpoint de ranking transforma qualquer valor diferente de company em escopo global, consulta UsuarioStats sem empresa_id e devolve ID, nome (com fallback para o nome civil) e URL assinada da foto dos três líderes. A tela abre em global e afirma que somente apelidos são exibidos.
Alta	backend/.env.example:7-8; backend/src/auth/auth.module.ts:20-25; backend/src/auth/jwt.strategy.ts:22-27	SEC-02 - Placeholder público de JWT é aceito como segredo válido. O .env.example publica JWT_SECRET=change-me-with-at-least-32-characters. O valor tem 37 caracteres, enquanto os dois validadores rejeitam apenas ausência ou comprimento menor que 32. Copiar o exemplo sem substituição inicia normalmente com um segredo conhecido por todos.
Média	commit 06bbb0c7f79939cded30218cf82d92571be6e9e2, backend/src/auth/constants.ts:3 e backend/src/auth/auth.module.ts:14	SEC-03 - Segredo JWT real permanece no histórico alcançável. O commit inicial contém um literal JWT de 32 caracteres em constants.ts e o conecta ao JwtModule. A ancestralidade confirma que o commit continua alcançável por developer, main, origin/developer, origin/main e origin/master. O valor foi redigido.

05 Achados detalhados por categoria

1. Banco sem tranca / isolamento de tenant

ALTA

SEC-01 - Ranking global expõe identidade e foto entre empresas

Arquivo:linha. backend/src/dashboard/dashboard.controller.ts:9-17;
backend/src/dashboard/dashboard.service.ts:62-93,103-115;
frontend/src/components/sections/HomePage/Ranking/index.tsx:24-26,193-195

Descrição. O isolamento do projeto é manual por `usuario_id` e `empresa_id`. O endpoint de ranking transforma qualquer valor diferente de `company` em escopo global, consulta `UsuarioStats` sem `empresa_id` e devolve ID, nome (com fallback para o nome civil) e URL assinada da foto dos três líderes. A tela abre em global e afirma que somente apelidos são exibidos.

Por que é explorável. Qualquer usuário autenticado da empresa A chama `GET /dashboard/ranking`, sem parâmetro ou com `scope=global`, e recebe dados de líderes da empresa B. Não é necessário adivinhar IDs nem possuir papel administrativo.

Impacto. Quebra de confidencialidade cross-tenant com exposição de nome, foto temporariamente acessível, nível e pontuação. O risco é agravado porque o produto é voltado a estudantes e a UI promete não expor dados pessoais.

Condição. Explorável quando existem usuários de mais de uma empresa com `UsuarioStats`. Se ranking global for requisito explícito, ainda é necessário pseudonimizar obrigatoriamente e retirar fotos/dados identificáveis sem consentimento.

Correção. Tornar `company` o escopo padrão e aplicar `empresa_id` em todas as queries. No modo global, retornar somente pseudônimo aprovado ou alias determinístico, nunca `name/profile_image_key`, e cobrir o contrato com testes entre tenants.

```
// dashboard.controller.ts:14-17
return this.dashboardService.getRanking(
  req.user.userId,
  scope === 'company' ? 'company' : 'global',
);

// dashboard.service.ts:80-83,103-115
if (scope === 'company' && company) {
  query.andWhere('u.empresa_id = :empresaId', { empresaId: company.id });
}
name: entry.usuario?.nickname ?? entry.usuario?.name ?? `Aventureiro ${index + 1}`,
profileImageUrl: await this.resolveProfileImageUrl(entry.usuario?.profile_image_key),
```

2. Permissão definida no navegador

Sem achado confirmado. Gates React para `platform_admin` e `admin` foram cruzados com `PlatformAdminController` (`@Roles(PLATFORM_ADMIN)`) e `AdminController` (`@Roles(ADMIN)`). Catálogos, uploads e quizzes exigem `PLATFORM_ADMIN` no servidor.

3. IDOR

Sem achado confirmado. A revisão percorreu todos os handlers. IDs em notificações, convites, usuários, aulas, desafios, partidas e cosméticos chegam a consultas com `usuario_id/empresa_id`, a `token/run` do caller ou a rotas exclusivas da plataforma.

4. Chaves expostas

ALTA**SEC-02 - Placeholder público de JWT é aceito como segredo válido**

Arquivo:linha. backend/.env.example:7-8; backend/src/auth/auth.module.ts:20-25;
backend/src/auth/jwt.strategy.ts:22-27

Descrição. O .env.example publica JWT_SECRET=change-me-with-at-least-32-characters. O valor tem 37 caracteres, enquanto os dois validadores rejeitam apenas ausência ou comprimento menor que 32. Copiar o exemplo sem substituição inicia normalmente com um segredo conhecido por todos.

Por que é explorável. Conhecendo o valor público, um atacante assina JWT aceito pelo Passport com sub escolhido e role=platform_admin, obtendo os endpoints globais de empresas, usuários, convites e mídia.

Impacto. Bypass total de autenticação e autorização no ambiente configurado com o placeholder.

Condição. Requer que um operador copie o exemplo e não troque JWT_SECRET. O render.yaml oficial usa generateValue=true e não está vulnerável a essa condição; outros deploys e ambientes compartilhados estão.

Correção. Deixar o campo vazio ou usar marcador rejeitado explicitamente. Centralizar a validação, bloquear uma denylist de placeholders conhecidos e documentar geração criptograficamente aleatória.

```
# backend/.env.example:8
JWT_SECRET=change-me-with-at-least-32-characters

// auth.module.ts:20-25
const secret = config.get<string>('JWT_SECRET')?.trim();
if (!secret || secret.length < 32) {
  throw new Error('JWT_SECRET deve estar definido e ter ao menos 32 caracteres');
}
```

MÉDIA**SEC-03 - Segredo JWT real permanece no histórico alcançável**

Arquivo:linha. commit 06bbb0c7f79939cded30218cf82d92571be6e9e2, backend/src/auth/constants.ts:3 e
backend/src/auth/auth.module.ts:14

Descrição. O commit inicial contém um literal JWT de 32 caracteres em constants.ts e o conecta ao JwtModule. A ancestralidade confirma que o commit continua alcançável por developer, main, origin/developer, origin/main e origin/master. O valor foi redigido.

Por que é explorável. Qualquer pessoa com leitura do repositório recupera o segredo e, se algum ambiente ainda o aceitar, forja tokens com qualquer sub e role. Remover o literal somente do estado atual não revoga o material histórico.

Impacto. Possível falsificação de sessão e elevação a platform_admin em ambientes não rotacionados.

Condição. Explorável somente se o segredo histórico ainda estiver configurado em algum ambiente. O código atual usa variável de ambiente; valores de infraestrutura não foram inferidos do repositório.

Correção. Rotacionar JWT em todos os ambientes, invalidar sessões e reescrever todas as refs/tags com o blob. Adicionar varredura de segredos no CI e proteção de push.

```
// commit 06bbb0c7..., backend/src/auth/constants.ts:2-4
export const jwtConstants = {
  secret: '<REDACTED>', // literal de 32 caracteres
};

// mesmo commit, backend/src/auth/auth.module.ts:14
secret: jwtConstants.secret,
```

5. Inputs sem tratamento (XSS)

Sem achado confirmado. Não existem dangerouslySetInnerHTML, innerHTML, srcDoc, parser Markdown/HTML, eval/new Function alimentado por usuário ou templates de e-mail HTML. URLs dinâmicas aparecem em img/video e vêm de uploads tipados, S3 assinado ou catálogos de PLATFORM_ADMIN. Não há sanitizador, mas também não há sink HTML que o exija hoje.

06 Cobertura sistemática das rotas

Cada controller abaixo foi cruzado com seu service e query/efeito. A única exceção confirmada está marcada como SEC-01.

Arquivo	Cobertura	Verificação	Resultado
platform-admin.controller.ts	12 / 12	@Roles(PLATFORM_ADMIN) na classe; acesso global intencional	Correto
admin.controller.ts	9 / 9	@Roles(ADMIN); empresa derivada do req.user	Correto
convites.controller.ts	2 / 2	Públicos por token aleatório; cadastro usa lock pessimista	Correto
notification.controller.ts	5 / 5	Criação/lista same-company; leitura/exclusão por dono	Correto
dashboard.controller.ts	5 / 5	Caller nos fluxos; ranking global quebra tenant	SEC-01
challenge.controller.ts	5 / 5	Caller + ensureDailyChallenge nas rotas por ID	Correto
aula.controller.ts	7 / 7	Leitura/progresso validam desbloqueio; CRUD só plataforma	Correto
modulo.controller.ts	5 / 5	Progresso do caller; CRUD só plataforma	Correto
aula-quiz.controller.ts	3 / 3	Catálogo global mutável só por plataforma	Correto
upload.controller.ts	1 / 1	Só plataforma; MIME, tamanho e chave controlados	Correto
ui-assets.controller.ts	1 / 1	Autenticado; catálogo de chaves fixas	Correto
achievements.controller.ts	6 / 6	Dados e itens possuídos filtrados por usuario_id	Correto
arcade.controller.ts	4 / 4	Run Redis inclui usuario_id; caller controla economia	Correto
usuario.controller.ts	3 / 3	Perfil usa exclusivamente req.user.userId	Correto
auth.controller.ts	5 paths	Login público; me/password/logout vinculados à sessão	Correto
benefits.controller.ts	3 / 3	Leitura pública; mutações só plataforma	Correto
app.controller.ts	3 paths	Health público; home autenticado	Correto

07 Recomendações priorizadas

Prioridade	Ação	Resultado esperado	Refs.
P1	Isolar o ranking	Empresa como padrão; pseudônimo obrigatório e nenhuma foto/ID pessoal no global.	SEC-01
P2	Rotacionar JWT	Gerar segredo novo e invalidar tokens antigos.	SEC-02/03
P3	Rejeitar placeholders	Validador único com denylist; .env.example sem segredo funcional.	SEC-02
P4	Limpar o Git	Reescrever refs/tags e habilitar secret scanning no CI.	SEC-03
P5	Testes de fronteira	Adicionar e2e A/B para ranking, admin, notificações e IDs.	Defesa

Ordem. Corrigir o ranking primeiro porque a exposição ocorre no fluxo normal. Rotacionar JWT antes de limpar o histórico, pois reescrever Git não invalida segredos já copiados.

08 Issues para o GitHub

Textos completos em Markdown, prontos para copiar e colar. Nenhuma issue foi publicada. SEC-02 e SEC-03 foram agrupados por tratarem do mesmo ciclo de vida de segredo JWT.

```

--- ISSUE 1 ---
# [Segurança] Isolar e pseudonimizar o ranking global

Labels sugeridas: `security`, `severity:high`

## Descrição do problema
O endpoint `GET /dashboard/ranking` usa escopo global quando o parâmetro é omitido ou diferente de `company`. Nesse modo, as queries não recebem `empresa_id` e a resposta inclui ID, nome (com fallback para o nome civil) e URL assinada da foto dos três líderes.

Isso é explorável por qualquer usuário autenticado: uma conta da empresa A obtém identidade, foto, nível e pontuação de usuários da empresa B. A tela abre em global e afirma que somente apelidos são mostrados.

## Evidência
`backend/src/dashboard/dashboard.controller.ts:9-17`
```ts
return this.dashboardService.getRanking(
 req.user.userId,
 scope === 'company' ? 'company' : 'global',
);
```

`backend/src/dashboard/dashboard.service.ts:62-93,103-115`
```ts
if (scope === 'company' && company) {
 query.andWhere('u.empresa_id = :empresaId', { empresaId: company.id });
}
name: entry.usuario?.nickname ?? entry.usuario?.name ?? `Aventureiro ${index + 1}`,
profileImageUrl: await this.resolveProfileImageUrl(entry.usuario?.profile_image_key),
```

`frontend/src/components/sections/HomePage/Ranking/index.tsx:24-26,193-195`
```tsx
const [selectedScope, setSelectedScope] = useState<'global' | 'company'>('global');
<p>Os colegas aparecem com apelidos de aventura. Assim, todos podem se divertir sem expor dados pessoais.</p>
```

## Impacto
Quebra cross-tenant de confidencialidade, com risco elevado por envolver estudantes e fotos de perfil.

## Sugestão de correção
Tornar o ranking da empresa o padrão e aplicar `empresa_id` a todas as queries. Se ranking global for requisito, retornar apenas pseudônimo aprovado ou alias determinístico, sem nome civil, foto ou identificador estável, e documentar consentimento/retenção.

## Critérios de aceite
- [ ] Sem parâmetro, o endpoint retorna somente usuários da empresa do chamador.
- [ ] `scope=company` aplica `empresa_id` em top, contagens, posição e próximo colocado.
- [ ] O modo global nunca retorna `name`, `profile_image_key` nem URL de foto de outro tenant.
- [ ] Usuário sem apelido aprovado recebe alias não identificável, sem fallback para nome civil.
- [ ] Teste e2e com empresas A e B prova ausência de dados identificáveis cross-tenant.
- [ ] O texto da UI descreve exatamente os dados que o backend devolve.
--- FIM ISSUE 1 ---

```

```
--- ISSUE 2 ---
# [Segurança] Corrigir ciclo de vida dos segredos JWT

Labels sugeridas: `security`, `severity:high`

## Descrição do problema
Há dois problemas relacionados. Primeiro, `backend/.env.example` publica `JWT_SECRET=change-me-with-at-least-32-characters`; o valor possui 37 caracteres e passa nas validações que só exigem comprimento mínimo de 32. Um ambiente criado ao copiar o exemplo aceita segredo conhecido.

Segundo, o commit `06bbb0c7f79939cded30218cf82d92571be6e9e2` preserva segredo JWT real de 32 caracteres e continua ancestral das branches locais e remotas principais. O valor deve permanecer redigido em issues e logs.

## Evidência
`backend/.env.example:7-8`
```env
Gere um segredo aleatório com pelo menos 32 caracteres.
JWT_SECRET=change-me-with-at-least-32-characters
```

`backend/src/auth/auth.module.ts:20-25` e `backend/src/auth/jwt.strategy.ts:22-27`
```ts
const secret = config.get<string>('JWT_SECRET')?.trim();
if (!secret || secret.length < 32) {
 throw new Error('JWT_SECRET deve estar definido e ter ao menos 32 caracteres');
}
```

`06bbb0c7...:backend/src/auth/constants.ts:3` e `auth.module.ts:14`
```ts
secret: '<REDACTED>', // literal real de 32 caracteres
secret: jwtConstants.secret,
```

## Impacto
Se o placeholder ou segredo histórico for aceito, um atacante assina JWT com `role=platform_admin` e assume controle administrativo da plataforma.

## Sugestão de correção
Esvaziar o exemplo ou usar marcador explicitamente proibido; centralizar validação e rejeitar placeholders conhecidos. Rotacionar JWT em todos os ambientes, invalidar sessões e reescrever todas as refs/tags com o blob. Adicionar scanner de segredos no CI e proteção de push.

## Critérios de aceite
- [ ] Startup falha com `change-me-with-at-least-32-characters` e demais placeholders documentados.
- [ ] `env.example` não contém valor utilizável como segredo funcional.
- [ ] Produção/homologação usam segredo aleatório novo; sessões antigas deixam de validar.
- [ ] Todas as branches e tags são reescritas e sincronizadas sem o blob vulnerável.
- [ ] Varredura de todos os objetos Git não encontra o segredo redigido.
- [ ] CI bloqueia novos segredos e testa a validação centralizada.
--- FIM ISSUE 2 ---
```

09 QA e encerramento

Integridade. O relatório não contém o valor do segredo histórico. Evidências sensíveis foram redigidas; nenhum dado foi publicado e nenhuma issue externa foi criada.

Artefato. PDF A4 com margens de aproximadamente 2 cm, gráficos vetoriais, tabelas com cabeçalho repetido e cabeçalho/rodapé paginados. Todas as páginas foram rasterizadas e inspecionadas antes da entrega.

| Item | Resultado |
|----------------|---|
| Revisão Git | ecae0ef806fbd250917ee84aab7cbb5e4b39272d |
| Achados | 3 (2 altas, 1 média) |
| Rotas | 77 handlers / 79 paths / 17 controllers |
| Testes backend | 81 aprovados |
| Frontend | typecheck, assets e build aprovados |
| PDF | A4; pdfinfo, rasterização e inspeção visual aprovados |